QPCODE: **Reg.No : .....**

Name : .....

MAHATMA GANDHI UNIVERSITY, KOTTAYAM
FIFTH SEMESTER MGU-UGP (HONOURS) REGULAR EXAMINATION

Fifth Semester
MG5DSECFS309 - CYBER SECURITY AUDIT AND COMPLIANCE

(2024 ADMISSION ONWARDS)

Duration: 2 Hours **Maximum Marks: 70**

Remember(K), Understand(U), Apply(A), Analyse(An), Evaluate(E), Create(C), Skill(S), Interest(I) and Appreciation(Ap)

Students should attempt at least one question from each course outcome to enhance their overall outcome attainability.

Part A
Very Short Answer Questions
Answer any 10 questions
Each question carries 2 marks

1. Explain the significance of the 6-hour incident reporting timeline mandated by CERT-In directives. [Understand]/[CO2]
2. Differentiate between a cyber security audit and an automated vulnerability assessment. [Understand]/[CO1]
3. Describe the specific purpose of the 'Condition' element in the CCCER audit reporting model. [Understand]/[CO4]
4. Distinguish between Spoofing and Tampering threats as categorized under the STRIDE model. [Understand] / [CO3]
5. Summarize the primary purpose of defining Terms of Reference (ToR) in an audit engagement. [Understand] / [CO1]
6. Explain how Corrective and Preventive Action (CAPA) tracking facilitates audit remediation. [Understand] / [CO4]
7. Illustrate one practical use case of Computer Assisted Audit Techniques (CAATs) during data sampling. [Apply]/[CO3]
8. Distinguish between preventive and detective security controls with one brief example of each. [Understand]/ [CO2]
9. Explain the core concept of the Defense-in-Depth strategy in protecting enterprise IT assets. [Understand]/[CO1]

10. Describe the main objective of performing Root Cause Analysis (RCA) on identified security findings. [Understand] / [CO4]

11. Calculate the qualitative risk rating when Likelihood is Medium and Impact is High in a standard 3×3 risk matrix. [Apply] / [CO3]

12. Summarize why digital audit trail preservation is critical for post-audit verification and compliance. [Understand] / [CO4]

[2 × 10 = 20]

Part B
Short Answer Questions
Answer any 6 questions
Each question carries 5 marks

13. Illustrate the key compliance obligations of Data Fiduciaries under India's Digital Personal Data Protection (DPDP) Act. [Apply]/[CO2]

14. Distinguish between Internal, External, and Third-Party audits in terms of auditor independence, reporting hierarchy, and audit objectives. [Understand]/[CO1]

15. Implement the legal requirements for electronic record admissibility under Section 65B of the Indian Evidence / IT Act during an evidence collection process. [Apply]/[CO2]

16. Examine how combining Nmap TCP SYN scanning, service version detection, and OS fingerprinting improves the accuracy of a technical vulnerability audit compared to standard port scanning. [Analyse] / [CO3]

17. Draft a concise executive summary of high-risk audit findings tailored for presentation to the Board of Directors. [Skill] / [CO4]

18. Implement Role-Based Access Controls (RBAC) combined with Dual Authorization to enforce Segregation of Duties (SoD) in an enterprise payroll transaction workflow. [Apply]/[CO2]

19. Explain the differences between General IT Controls (GITC) and Application Controls, providing practical examples of each in enterprise risk reduction. [Understand] / [CO1]

20. Use HIPAA Security Rule audit safeguards (Administrative, Physical, and Technical) to assess an electronic Protected Health Information (ePHI) cloud repository. [Apply]/[CO2]

[5 × 6 = 30]

Part C

Essay Questions

Answer any 2 questions

Each question carries 10 marks

21. (a) Examine the threat profile of a three-tier online banking portal by categorizing vulnerabilities using the STRIDE threat model and evaluating their severity. [Analyse] / [CO3]

    (b) Implement a SIEM-based log auditing and correlation procedure aligned with CIS Benchmarks to detect and alert on unauthorized privilege escalation. [Apply]/[CO3]

22. (a) Construct a formal Cyber Security Audit Finding for an unpatched external-facing server vulnerability utilizing all five elements of the CCCER model. [Skill]/[CO4]

    (b) Explain the complete post-audit workflow encompassing Root Cause Analysis (RCA), remediation re-testing, corrective action tracking, and formal audit closure. [Understand] / [CO4]

23. (a) Employ the core control domains of the ISO/IEC 27001 ISMS standard to design an internal audit compliance verification checklist for an enterprise data center. [Apply]/[CO2]

    (b) Implement an operational policy framework to ensure mandatory compliance with CERT-In directives (6-hour incident reporting window and 180-day log retention). [Apply]/[CO2]

[10 × 2 = 20]